

Disclaimer for Course Information

- ▶ These course materials are for educational purposes only and shall not constitute professional advice in any form to anyone
- ▶ These course materials have been designed as an integral part of the course presentation and are intended solely for the benefit of delegates attending the respective course(s). These course materials do not necessarily stand on their own and are not intended to be relied upon for giving specific professional advice
- ▶ Best endeavours are used to ensure that these course materials are up-to-date when recorded/printed. However, given the nature of the subject, professional advice should be taken before taking any specific step in relation to any matter
- ▶ Nothing said or done by EY or its course presenters can be relied upon as professional advice by anyone viewing/attending the elearning(s)/course(s) or anyone else viewing/reading these materials. Any comments made by any course presenter does not constitute professional advice and must not be relied upon as professional advice by anyone viewing/attending the elearning(s)/course(s) or anyone else
- ▶ All title, intellectual property and copyrights and other rights in these materials are owned by EY or its suppliers. All such rights are reserved and remained vested in EY or its suppliers, and are not transferred in any way
- ▶ No part of these course materials may be reproduced in any form, in whole or in part, for any purpose without the prior permission in writing of EY. No part of these course materials shall be stored in any electronic knowledge-base, or data retrieval system without the prior permission in writing of EY



Cybersecurity Basics for Business Professionals

Jain Online MCC ▶ 4 Sessions ▶ 10 AM - 1 PM ▶ May-June 2026



Shape the future
with confidence

Cybersecurity Basics for Business Professionals



About the Program

The program introduces essential cybersecurity concepts tailored for business and non-technical professionals. It explains how modern cyber threats affect organizations, operations, and decision-making. The focus is on building awareness and understanding risk rather than technical implementation. The program helps business users adopt secure practices and work effectively with cybersecurity teams.

- Introduces fundamental cybersecurity concepts for business professionals.
- Explains real-world cyber threats impacting businesses and operations.
- Focuses on awareness, risk understanding, and informed decision-making.
- Bridges the gap between business functions and cybersecurity teams



Program Objectives

The objective of the program is to build awareness of cybersecurity risks and common threat types relevant to business environments. Enable professionals to identify and assess cyber risks within everyday operations and decisions. Promote secure digital behavior and responsible handling of organizational data. Strengthen collaboration between business teams and IT or cybersecurity functions.

- Enable identification of common cyber risks in business environments.
- Promote secure digital behavior and data protection awareness.
- Strengthen collaboration between business and IT/security stakeholders



Expected Learning Outcomes

Participants will be able to recognize common cyber threats such as phishing, malware, and data breaches. They will demonstrate improved understanding of secure practices for email usage, passwords, and data handling. Learners will gain awareness of privacy, compliance, and organizational cybersecurity responsibilities. Participants will confidently apply cybersecurity principles in everyday business decisions.

- Improved understanding of safe practices for emails, passwords, and data.
- Awareness of privacy, compliance, and organizational cyber responsibilities.
- Confidence to apply cybersecurity principles in daily business decisions



Program Structure Overview

The program starts with an overview of cybersecurity fundamentals, covering threats, risks, and key concepts. It then focuses on business impact and risk awareness, highlighting financial, legal, and reputational implications. Secure practices are emphasized through guidance on data protection and safe digital behavior. The program concludes with governance, compliance, and shared responsibility for cybersecurity across teams.

- **Cybersecurity Fundamentals** - Threat landscape, risks, and key concepts.
- **Business Impact & Risk Awareness** - Financial, legal, and reputational impact.
- **Secure Practices & Behavior** - Data protection, access control, safe usage.
- **Governance & Responsibility** - Policies, compliance, and cyber accountability

Coverage

- 01 Understanding cybersecurity fundamentals and key terminology for business users
- 02 Overview of the modern cyber threat landscape impacting organizations
- 03 Common cyber threats including phishing, malware, and ransomware
- 04 Business impact of cyber incidents on finance, operations, and reputation
- 05 Cyber risk awareness in everyday business processes and decision-making
- 06 Safe email usage, password hygiene, and identity protection practices
- 07 Data protection principles and secure handling of sensitive information
- 08 Remote work and digital workplace security best practices
- 09 Role of employees in preventing and reporting cyber incidents
- 10 Introduction to privacy, compliance, and data protection regulations
- 11 Understanding organizational cybersecurity policies and responsibilities
- 12 Building a culture of shared cyber accountability across business teams

Course Agenda

Session 1 – 17 May

Topics 1-3: Fundamentals, Threat Landscape, Common Threats

Session 2 – 24 May

Topics 4-6: Business Impact, Risk Awareness, Safe Practices

Session 3 – 31 May

Topics 7-9: Data Protection, Remote Work, Employee Role

Session 4 – 7 June

Topics 10-12: Privacy/Compliance, Policies, Cyber Culture

SESSION 1

Sunday, 17 May 2026
10:00 AM - 1:00 PM

Topics Covered: 1 · 2 · 3

Cybersecurity Fundamentals | Modern Threat Landscape | Common Cyber Threats

Topic 1

Understanding Cybersecurity Fundamentals & Key Terminology

01

The language, core concepts, and mental models every business professional must know.

What Is Cybersecurity?

- Cybersecurity is the practice of protecting systems, networks, programs, and data from digital attacks, damage, or unauthorized access.
- CIA Triad – Confidentiality (only authorized access), Integrity (data is accurate & untampered), Availability (systems accessible when needed).
- Cyber threat: Any potential danger that exploits a vulnerability to breach security & cause harm.
- Asset: Anything of value – data, devices, systems, people, reputation.
- Vulnerability: A weakness in a system, process, or control that can be exploited.
- Exploit: A method or tool used to take advantage of a vulnerability.
- Risk = Threat × Vulnerability × Impact – the foundational formula for all cyber decisions.

Core Security Concepts Every Professional Must Know

Technical Terms Simplified

- Firewall – Digital gatekeeper controlling network traffic
- Encryption – Scrambles data so only authorized parties can read it
- Authentication – Proving who you are (password, fingerprint, OTP)
- Authorization – What you're allowed to do once authenticated
- Patch / Update – Fixing known security vulnerabilities in software
- Endpoint – Any device connecting to the network (laptop, phone, IoT)
- VPN – Virtual Private Network; encrypted tunnel over public internet

Business-Relevant Concepts

- Attack Surface – All points where an adversary can enter your environment
- Least Privilege – Users get only the access they need, nothing more
- Defense in Depth – Multiple security layers; one failure doesn't collapse everything
- Zero Trust – 'Never trust, always verify'; no implicit trust for anyone
- Incident – An event that compromises security of information assets
- Threat Actor – Anyone who poses a cyber threat: criminal, insider, nation-state
- Due Diligence – Reasonable precautions expected of responsible businesses

Why Cybersecurity Matters – By the Numbers (2024)

\$9.5T

Global Cybercrime Cost
2024

Annual global cost of
cybercrime – exceeds GDP of
most nations (Cybersecurity
Ventures, 2024)

277

Days to Identify a Breach

Average time to identify and
contain a data breach before
action is taken (IBM Cost of a
Data Breach 2024)

82%

Breaches Involve Humans

Vast majority of breaches
involve human element –
phishing, errors, misuse
(Verizon DBIR 2024)

\$4.88M

Average Breach Cost

Average total cost of a data
breach globally, highest in 19
years of IBM research (IBM,
2024)

Common Cybersecurity Misconceptions vs. Reality

Misconception

- 'We are too small to be attacked' – SMEs are primary targets; automated tools scan all IPs equally.
- 'Our IT department handles security' – 82% of breaches involve human error by non-IT staff.
- 'Antivirus is enough' – Modern attacks evade signature-based detection; behaviour-based tools are needed.
- 'We have insurance, so we are covered' – Insurance doesn't restore reputation or prevent fines.
- 'Strong passwords are sufficient' – Credential stuffing and phishing bypass even complex passwords.

Reality

- Every connected business is a target – attackers prefer SMEs precisely because defences are weaker.
- Security is every employee's job; IT provides tools but people make the daily decisions.
- Defence-in-depth (firewall + EDR + training + MFA + backups) is the minimum viable posture.
- Regulatory fines, litigation, and reputational damage are NOT covered by most cyber policies.
- MFA stops 99.9% of account compromise attacks – password alone is not enough (Microsoft, 2023).

The Attack Lifecycle – How Hackers Actually Work

- Reconnaissance: Attacker gathers intelligence – LinkedIn, WHOIS, job postings, public GitHub code, company website metadata.
- Weaponization: Attacker crafts a payload – phishing email with malicious macro, exploit kit, trojanized software.
- Delivery: Payload sent via email, USB, watering-hole website, or compromised vendor software.
- Exploitation: Vulnerability is triggered – a click, a macro, an unpatched system hands over a foothold.
- Installation: Malware establishes persistence – autorun keys, scheduled tasks, service installation.
- Command & Control (C2): Attacker communicates with infected machine, often via HTTPS to blend in.
- Actions on Objectives: Data exfiltration, ransomware deployment, lateral movement to high-value targets.
- Business takeaway: Defenders can break the chain at ANY stage – early detection stops catastrophic impact.

Class Exercise: Spot the Vulnerability

- SCENARIO A: A finance manager uses the same password for her bank, Office 365, and LinkedIn. LinkedIn is breached. What is the risk chain?
- SCENARIO B: A vendor is given admin access to your CRM 'temporarily' for a 3-day integration project. Six months later, the vendor is acquired. What risks persist?
- SCENARIO C: A sales director emails a 10MB spreadsheet of 5,000 customer records to their personal Gmail to work from home. Which security principles are violated?
- SCENARIO D: Your company runs Windows 7 on factory floor PCs because upgrading would disrupt production. EternalBlue (WannaCry exploit) is public. What is your risk?
- DISCUSSION: For each scenario – identify the threat, vulnerability, and likely impact. What single control would reduce risk the most?
- KEY INSIGHT: Every scenario above has caused real multi-million dollar incidents. None required sophisticated hacking – only basic security hygiene failures.

Target Corporation Data Breach ► 2013

What Happened

Attackers gained access to Target's network via a third-party HVAC vendor's credentials. They installed malware on point-of-sale systems and stole 40 million credit/debit card records and 70 million personal records over 3 weeks before detection.

Business Impact

Target paid \$202M in settlements. CEO resigned. Customer trust plummeted. Stock dropped 46% in months after. Security budget doubled. The breach exposed that a retailer's security is only as strong as its weakest vendor.

Key Lesson

Third-party vendor risk is YOUR risk. Least-privilege access, network segmentation, and vendor security assessments are not optional. Business teams must include cybersecurity in ALL vendor onboarding.

1. NIST Cybersecurity Framework (CSF) 2.0

Free Framework / Open Source ▶ National Institute of Standards and Technology

<https://www.nist.gov/cyberframework>

2. Cybersecurity Ventures Annual Report 2024

Industry Report ▶ Cybersecurity Ventures

<https://cybersecurityventures.com>

3. IBM Cost of a Data Breach Report 2024

Research Report (Free) ▶ IBM Security

<https://www.ibm.com/reports/data-breach>

4. Verizon Data Breach Investigations Report 2024

Open Source Annual Report ▶ Verizon Enterprise

<https://www.verizon.com/business/resources/reports/dbir/>

5. "Cybersecurity Essentials" – Cisco NetAcad

Free Online Course ▶ Cisco Networking Academy

<https://www.netacad.com/courses/cybersecurity>

02

Topic 2

Overview of the Modern Cyber Threat Landscape

How threats have evolved, who the adversaries are, and what industries are most targeted.

Evolution of the Threat Landscape

- 1980s-90s: Hobbyist hackers, early viruses spread via floppy disks. Motivation: curiosity and notoriety.
- 2000s: Organized cybercrime emerges. Mass email worms (ILOVEYOU, Melissa). Financial fraud becomes primary motive.
- 2010s: Nation-state attacks (Stuxnet, APT campaigns). Ransomware explosion. Cyber-espionage targets IP and government.
- 2020s: Supply chain attacks (SolarWinds), AI-powered attacks, deepfake fraud, ransomware-as-a-service (RaaS), and cloud-native threats.
- Today's reality: Attacks are faster, more automated, and more accessible. Anyone can buy a ransomware kit for \$200 on the dark web.
- Business impact: Attacks now disrupt operations, destroy reputation, trigger regulatory fines, and hold data hostage for millions.

Who Are the Threat Actors?

External Threat Actors

- Cybercriminals – Financially motivated; steal data, extort via ransomware
- Nation-State Actors – Government-sponsored; conduct espionage, sabotage critical infrastructure
- Hacktivists – Ideology-driven; deface websites, leak data (Anonymous)
- Script Kiddies – Low-skill attackers using pre-built tools; still dangerous
- Cyber Terrorists – Seek to cause fear, disrupt society, damage infrastructure
- Competitors – Corporate espionage; steal R&D, customer lists, pricing

Internal Threat Actors

- Malicious Insiders – Employees who steal or sabotage intentionally
- Negligent Employees – Accidental data loss, clicking phishing links, misconfigurations
- Compromised Insiders – Legitimate users whose credentials were stolen
- Third-Party Vendors – Contractors with privileged access; supply chain risk
- Shadow IT Users – Employees using unsanctioned apps outside IT oversight
- Former Employees – Ex-staff retaining access post-departure

Emerging Threats: AI-Powered Attacks & Deepfakes

- AI-generated phishing: LLMs craft highly personalized, grammatically perfect phishing emails in any language – old 'bad grammar' detection fails.
- Deepfake voice fraud: In 2024, a Hong Kong company transferred HK\$200M (\$26M) after a deepfake video call impersonating their CFO and board members.
- Automated vulnerability discovery: AI scans millions of lines of code to find exploitable flaws faster than human researchers.
- Polymorphic malware: AI rewrites malware code after every infection, evading signature-based detection entirely.
- AI-powered OSINT: Attackers compile detailed profiles from social media, publications, and public records to craft perfect spear-phishing lures.
- Fake audio in BEC: Short voice samples (from LinkedIn videos, conference recordings) used to clone executives' voices for urgent payment requests.
- Defence: Verify all financial requests via secondary channel (callback to KNOWN number). Out-of-band verification is the ONLY defence against deepfake fraud.
- Business policy: No wire transfer over threshold amount should be authorized based solely on an email or call – require dual approval and phone verification.

Dark Web & Cybercrime Economy – What Attackers Buy and Sell

- The dark web is a marketplace for stolen data, attack tools, and criminal services – think eBay for cybercrime.
- Stolen credentials: Username/password pairs sell for \$0.50-\$25 each. Corporate VPN access for \$3,000-\$50,000.
- Ransomware-as-a-Service (RaaS): Affiliates pay 20-30% commission to ransomware developers; no technical skill required.
- Initial Access Brokers (IABs): Specialized criminals who break into networks then sell access to ransomware groups.
- Phishing kits: Fully designed fake login pages for O365, banks, tax authorities – available for \$50-\$200.
- Stolen data value: Full identity package (name, SSN, DOB, credit card, medical) sells for \$150-\$200 per person.
- DDoS-for-hire: Attack any website for \$10-\$100/hour – no hacking skill required.
- Business implication: Attackers are NOT all elite hackers. The barrier to entry is low. Anyone with money can attack your business.

Advanced Persistent Threats (APTs) – Nation-State Level Attacks

What Makes APTs Different

- **Patience:** APTs may lurk undetected for months or years – average dwell time is 204 days.
- **Sophistication:** Zero-day exploits, custom malware, living-off-the-land (using your own tools against you).
- **Resources:** State-funded teams of specialist hackers working 9-to-5 in purpose-built facilities.
- **Objectives:** Espionage, IP theft, critical infrastructure disruption – not just quick financial gain.
- **Notable APT Groups:** Lazarus (North Korea), Cozy Bear / APT29 (Russia), APT41 (China).

Business Impact of APTs

- **IP theft:** R&D stolen before launch costs billions in competitive advantage lost.
- **Supply chain infiltration:** Compromise vendor to reach downstream targets (SolarWinds model).
- **Pre-positioned access:** APTs plant backdoors for activation during geopolitical crises.
- **Detection challenge:** APTs use legitimate tools (PowerShell, WMI) – traditional AV misses them.
- **Defence:** Threat intelligence feeds, EDR solutions, network anomaly detection, user behaviour analytics.

Most Targeted Industries – And Why

- Healthcare: Holds highly valuable patient PII and PHI; legacy systems; ransomware disrupts critical care. Avg breach cost: \$10.9M (IBM 2024).
- Financial Services: Direct path to money; payment systems, wire fraud, account takeover. 300× more targeted than other industries.
- Education: Vast amounts of student/staff PII, research data, underfunded security teams.
- Manufacturing: OT/IT convergence; ransomware can halt production lines; IP theft risk.
- Retail & E-commerce: Payment card data, loyalty program fraud, supply chain attacks.
- Government: Espionage, election interference, critical infrastructure disruption, citizen data theft.
- Professional Services (Law, Consulting, Accounting): Gateway to high-value client data; often have less security than the clients they serve.

SolarWinds Supply Chain Attack ► 2020

What Happened

Nation-state hackers (APT29 / Russia's SVR) inserted malicious code into SolarWinds Orion software updates. 18,000+ organizations – including US Treasury, Pentagon, and Fortune 500 companies – unknowingly downloaded the backdoored update.

Business Impact

9 federal agencies and 100+ private companies breached. Took months to detect. Cleanup cost estimated at \$100M+ per large organization. Demonstrated that even trusted software vendors are attack vectors.

Key Lesson

You cannot trust software simply because it comes from a known vendor. Third-party risk management, integrity verification of updates, and network monitoring for anomalous behavior are essential business-level practices.

1. ENISA Threat Landscape 2024

Annual Report (Free) ▶ European Union Agency for Cybersecurity

<https://www.enisa.europa.eu/topics/cyber-threats/enisa-threat-landscape>

2. MITRE ATT&CK Framework

Free Open-Source Knowledge Base ▶ MITRE Corporation

<https://attack.mitre.org>

3. Cybersecurity & Infrastructure Security Agency (CISA)

Government Resource ▶ US-CISA

<https://www.cisa.gov/topics/cybersecurity-best-practices>

4. Threat Intelligence Report Q1 2024

Industry Research ▶ CrowdStrike

<https://www.crowdstrike.com/resources/reports/>

5. Recorded Future Annual Threat Intelligence Report

Free Report ▶ Recorded Future

<https://www.recordedfuture.com/research>

03

Topic 3

Common Cyber Threats: Phishing, Malware & Ransomware

Deep dive into the three most damaging, business-relevant attack types.

Phishing – The #1 Attack Vector

- Phishing: Fraudulent communication that appears legitimate, designed to trick recipients into revealing credentials, clicking malicious links, or transferring money.
- Spear Phishing: Highly targeted phishing using personalized info (your name, role, boss's name) – 91% of all cyberattacks begin with a spear-phishing email.
- Whaling: Targets senior executives (CEO, CFO) to authorize large wire transfers or reveal strategic data.
- Smishing (SMS Phishing): 'Your package is on hold – click here.' Targets mobile devices.
- Vishing (Voice Phishing): Attacker calls posing as IT support, bank, or government official.
- Business Email Compromise (BEC): Impersonates CEO or vendor to trick finance teams. FBI reports \$50B+ lost globally to BEC 2013-2023.
- Red Flags: Urgency, generic greetings, mismatched sender domains, suspicious attachments, requests for credentials or payments.

Phishing Identification Workshop – Red Flags Checklist

Email Red Flags

- Sender domain mismatch – support@paypa1.com vs paypal.com
- Urgency + threat – 'Act now or lose access'
- Generic greeting – 'Dear Customer' or 'Dear User'
- Requests credentials, payment, or OTP via email
- Hover test fails – displayed URL differs from actual link
- Unexpected attachment – especially .exe, .docm, .xlsm, .zip
- Poor grammar or unusual phrasing (less reliable with AI phishing)
- Email asks you to bypass normal processes or policies

How to Verify Suspicious Emails

- DO NOT click links – type the URL directly in the browser
- DO NOT call numbers listed in the email – look up official number
- Check email headers – reveal true sender IP and mail path
- Contact sender via separate channel (phone/Teams) to confirm
- Forward to security team or click 'Report Phishing' button
- Check haveibeenpwned.com if credentials may be compromised
- NEVER provide OTP, password, or card details via email
- When in doubt, do nothing – report and wait for guidance

Malware – The Many Faces of Malicious Software

Types of Malware

- Virus – Self-replicating code attached to files; spreads when file is shared
- Worm – Self-propagates across networks without human action
- Trojan – Disguised as legitimate software; creates backdoor
- Spyware – Silently monitors user activity; captures passwords, keystrokes
- Adware – Injects unwanted ads; often bundles spyware
- Rootkit – Hides deep in OS; gives attacker persistent access
- Keylogger – Records every keystroke; captures passwords silently
- Fileless Malware – Runs in memory; leaves no trace on disk

How Malware Spreads

- Phishing emails with malicious attachments or links
- Drive-by downloads from compromised websites
- Infected USB drives or external storage
- Malicious mobile apps from unofficial stores
- Software vulnerabilities and unpatched systems
- Peer-to-peer file sharing
- Supply chain compromise (pre-installed malware)
- Watering hole attacks targeting specific websites

Ransomware – The Billion-Dollar Threat

- Ransomware encrypts victim's files, rendering them inaccessible, then demands payment (typically cryptocurrency) for decryption keys.
- Ransomware-as-a-Service (RaaS): Criminal syndicates sell ransomware toolkits to affiliates who execute attacks – anyone can be an attacker.
- Double extortion: Not only encrypt data, but also threaten to publish sensitive data if ransom is unpaid.
- Triple extortion: Add DDoS attack on victim's website, plus direct demands to customers/partners.
- Average ransom demand (2024): \$2.73 million. Average downtime: 24 days. Many businesses never recover.
- Healthcare, education, and local government are prime targets – they often pay because downtime costs more.
- Prevention: Regular offline backups, patch management, email filtering, user training, incident response plans.

Ransomware Response – What to Do When You Are Hit

- STEP 1 – ISOLATE: Immediately disconnect infected machines from the network (unplug ethernet, disable Wi-Fi). DO NOT shut down – evidence may be lost.
- STEP 2 – ALERT: Notify IT/security team, CISO, and senior management immediately. Invoke Incident Response Plan.
- STEP 3 – SCOPE: Identify which systems are affected. Determine if backups are clean and offline/untouched.
- STEP 4 – DO NOT PAY (initially): Payment does not guarantee decryption. Average 35% of payers never receive keys. Paying funds future attacks.
- STEP 5 – LEGAL: Engage cybersecurity legal counsel. Paying ransomware groups on OFAC sanctions lists (e.g. North Korea's Lazarus) may be illegal.
- STEP 6 – NOTIFY: CERT-In (India) requires incident reporting within 6 hours. GDPR requires 72-hour notification if personal data affected.
- STEP 7 – RECOVER: Restore from verified clean backups. Rebuild affected systems rather than decrypt in place.
- STEP 8 – LEARN: Post-incident review to identify entry point, dwell time, and control failures. Update defences.

Social Engineering Deep Dive – The Human Hack

Psychological Triggers Attackers Exploit

- Authority: 'This is the CEO, I need this done immediately.' People comply with perceived authority figures.
- Urgency & Fear: 'Your account will be suspended in 2 hours.' Panic overrides rational thinking.
- Social Proof: 'Everyone on your team has already submitted their credentials for verification.'
- Reciprocity: 'I helped you with that IT problem last week, can you just give me access this once?'
- Scarcity: 'This offer expires at midnight, you must act now.' Creates irrational decision-making.
- Familiarity/Liking: Attackers research targets on LinkedIn to reference real colleagues and projects.

Real-World Social Engineering Tactics

- Vishing scripts: Attackers pose as IT support, banks, EPFO, or tax authorities with perfect scripts.
- Pretexting: Building a false scenario – 'I am the new IT auditor, I need to verify your credentials.'
- Baiting: Leaving USB drives in company car parks labelled 'Salary Survey 2024' – curiosity kills.
- Quid pro quo: 'I can fix your slow computer remotely, just let me install this remote access tool.'
- Defence: Slow down. Verify identity through official channels. Zero trust – verify ALL requests for access.
- Red flag: ANY request that bypasses normal process, creates urgency, or asks for exceptions.

WannaCry Global Ransomware Attack ► 2017

What Happened

WannaCry exploited a Windows vulnerability (EternalBlue, stolen from NSA). It self-propagated across networks, encrypting files on 200,000+ computers in 150 countries within 72 hours, demanding Bitcoin ransom.

Business Impact

NHS (UK) canceled 19,000 appointments and 80 hospitals reverted to pen-and-paper. FedEx, Telefonica, and Renault halted operations. Total damages: \$4-8 billion. All caused by unpatched Windows systems.

Key Lesson

Patching is not just an IT task – it is a business continuity imperative. Delayed updates of even 1 month cost organizations billions. Business leaders must mandate and fund regular patch cycles.

1. Anti-Phishing Working Group (APWG) Phishing Activity Trends Report

Free Quarterly Report ▶ APWG

<https://apwg.org/trendsreports/>

2. No More Ransom Project – Free Decryption Tools

Free Tool / Open Source ▶ Europol + Partners

<https://www.nomoreransom.org>

3. PhishTank – Community Phishing Database

Free Open-Source Database ▶ OpenDNS / Cisco

<https://phishtank.org>

4. Malwarebytes Threat Intelligence Blog

Free Blog / Research ▶ Malwarebytes Labs

<https://www.malwarebytes.com/blog/threat-intelligence>

5. CISA Ransomware Guide

Free Government Guide ▶ CISA / MS-ISAC

<https://www.cisa.gov/ransomware>

SESSION 2

Sunday, 24 May 2026
10:00 AM – 1:00 PM

Topics Covered: 4 · 5 · 6

Business Impact | Cyber Risk in Business Decisions | Email, Passwords & Identity Protection

Topic 4

Business Impact of Cyber Incidents: Finance, Operations & Reputation

Translating technical breaches into boardroom language – the real cost of cyberattacks on business.

Financial Impact of Cyber Incidents

- Direct Costs: Incident response fees (\$500-\$1,500/hr for forensics), ransom payments, legal fees, regulatory fines, credit monitoring for affected customers.
- GDPR fines: Up to 4% of global annual turnover or €20M – whichever is higher. Meta fined €1.2B in 2023.
- PCI DSS non-compliance fines: \$5,000-\$100,000 per month until compliant; withdrawal of card processing rights.
- Litigation: Class action lawsuits from affected customers and shareholders post-breach.
- Cyber insurance premiums have surged 50-100% year-over-year; coverage is tightening.
- Hidden costs: Lost productivity, emergency IT spend, customer acquisition to replace churned clients, staff overtime.
- Small businesses: 60% close within 6 months of a significant cyberattack (National Cyber Security Alliance).

Operational & Reputational Impact

Operational Disruptions

- Production/service halts – Manufacturing lines, hospital systems, logistics networks go offline
- Supply chain cascades – Attacks on one vendor disrupt dozens of downstream businesses
- Data unavailability – Critical business data encrypted or deleted
- Communication breakdown – Email, messaging, and collaboration tools compromised
- Customer service collapse – CRM and support systems unavailable
- Recovery timelines – Average recovery from ransomware: 3-5 weeks; major incidents: 6+ months

Reputational Damage

- Media coverage amplifies public awareness of breaches immediately
- Customer trust erosion – 81% say they'll stop engaging with a brand post-breach
- Partner relationships strained – Vendors require security certifications post-incident
- Stock price impact – Publicly traded companies see avg 7.5% stock drop after breach announcement
- Employee morale and retention affected – Staff don't want to work for breached organizations
- Long-term brand damage – Google-able forever; appears in due diligence searches for years

Communicating a Cyber Incident – Crisis Communication

Internal Communication

- CISO/IT notifies C-suite within 1 hour of confirmed incident.
- Incident response team assembled immediately – legal, PR, IT, operations.
- All-staff alert via phone/SMS (not email – may be compromised).
- Business continuity plan activated – manual processes if systems down.
- Legal privilege: Keep all incident communications through legal counsel.
- Document everything: Timeline, decisions, actions taken.

External Communication

- Regulators: CERT-In (6 hours), GDPR supervisory authority (72 hours), RBI/SEBI as applicable.
- Customers: Honest, factual, timely – delay amplifies damage. 54% say delayed disclosure worsens trust loss.
- Media: Prepare a holding statement. Avoid speculation. Designate a single spokesperson.
- Partners/Vendors: Notify if their data or systems may be at risk.
- NEVER: Lie, minimize, or go silent – regulators and media will find out.
- Hire a specialist cyber PR firm in advance – crisis prep, not crisis response.

Cyber Insurance – What It Covers, What It Doesn't

- What cyber insurance typically COVERS: Incident response costs, forensics, ransom negotiation, legal fees, regulatory fine defence, PR/crisis communications, business interruption losses.
- What it typically DOES NOT cover: Reputational damage (lost future revenue), criminal fines (GDPR penalties), war exclusions (some policies exclude nation-state attacks), pre-existing vulnerabilities.
- Underwriting questions have intensified: Insurers now require MFA, EDR, backup controls, and security training as prerequisites for coverage.
- Premium reality: A ₹100 crore revenue company may pay ₹30-80 lakh annually for ₹10 crore cyber coverage – and face significant exclusions.
- Claims denials: 30-40% of cyber claims are partially or fully denied due to policy exclusions or failure to implement required controls.
- The Lloyd's of London precedent: In 2024, Lloyd's added nation-state attack exclusions – potentially excluding coverage for state-sponsored ransomware.
- Key lesson: Cyber insurance is a LAST RESORT financial tool, not a security strategy. Controls reduce premiums AND losses.
- Due diligence: Have an insurance broker and legal counsel review your policy BEFORE you need it – not during an incident.

Colonial Pipeline Ransomware ► 2021

What Happened

DarkSide ransomware group attacked Colonial Pipeline – operator of the largest US fuel pipeline (2.5M barrels/day). Attackers accessed network via compromised VPN password with no MFA. Pipeline was shut down proactively to prevent spread.

Business Impact

Gas shortages across 17 US states. Panic buying. Average gas prices hit 7-year high. Company paid \$4.4M ransom (partially recovered). US declared national emergency. CEO testified before Congress. Led directly to new pipeline cybersecurity regulations.

Key Lesson

MFA (Multi-Factor Authentication) on ALL remote access – no exceptions – could have prevented this entirely. One stolen password stopped the fuel supply for half a nation. Business leaders must treat access control as a board-level priority.

1. IBM Cost of a Data Breach Report 2024

Annual Research Report (Free Download) ▶ IBM Security

<https://www.ibm.com/reports/data-breach>

2. Ponemon Institute – Cost of Cyber Crime Study

Research Report ▶ Accenture / Ponemon

<https://www.accenture.com/us-en/insights/security/cost-cybercrime-study>

3. Cyber Incident Reporting for Critical Infrastructure Act (CIRCIA)

Regulation Overview ▶ CISA

<https://www.cisa.gov/circia>

4. GDPR Fine Tracker

Live Database (Free) ▶ Enforcement Tracker

<https://www.enforcementtracker.com>

5. WEF Global Cybersecurity Outlook 2024

Free Report ▶ World Economic Forum

<https://www.weforum.org/reports/global-cybersecurity-outlook-2024>

Topic 5

Cyber Risk Awareness in Everyday Business Decisions

Every business decision has a cyber dimension – procurement, partnerships, HR, operations, and strategy.

The Business Risk Lens – NIST Framework for Non-Technical Leaders

- Risk = Likelihood × Impact. Business leaders manage this equation daily – cybersecurity is no different.
- NIST CSF 2.0 Five Functions: GOVERN (strategy, roles, risk management) → IDENTIFY (assets, risks) → PROTECT (safeguards) → DETECT (anomalies) → RESPOND (contain) → RECOVER (restore).
- Cyber risk appetite: Organizations must define how much cyber risk they are willing to accept – like financial risk – and communicate it to all departments.
- Every business process has a digital shadow: HR holds employee PII, Finance holds payment data, Legal holds privileged communications, Sales holds customer data.
- Risk prioritization: Not all assets are equal. Identify crown jewels (most valuable/sensitive data/systems) and protect them first.
- Risk transfer: Cyber insurance transfers financial impact but NOT operational, legal, or reputational risk.

Cyber Risk in Everyday Business Decisions

High-Risk Decisions (with Cyber Implications)

- Onboarding a new vendor – Are their security practices audited? What data do they access?
- Adopting a new SaaS app – Where is data stored? Who owns it? Is it GDPR compliant?
- Mergers & Acquisitions – Target's cyber debt becomes acquirer's liability
- Hiring contractors/freelancers – What devices do they use? What access do they need?
- Moving to cloud – Shared responsibility model: provider secures infrastructure, YOU secure data
- Launching a new product/service – Privacy-by-design must be built in, not bolted on

Building Cyber Risk Culture

- Include cybersecurity in ALL vendor due diligence checklists
- Require security questionnaires for any vendor handling sensitive data
- Conduct cyber risk assessments before major IT/business changes
- Involve CISO/IT security in strategic planning sessions
- Create a risk register that includes cyber risks alongside financial/operational risks
- Report cyber risk metrics to board – breach likelihood, controls effectiveness
- Reward employees for reporting suspicious activity – no blame culture

Third-Party & Supply Chain Risk Management

- Why it matters: 62% of organizations experienced a breach caused by a third-party vendor (Ponemon, 2023). You inherit your vendors' vulnerabilities.
- Attack path: Attacker compromises small vendor with weak security → uses that access to pivot into your network → your data is stolen.
- Vendor risk tiers: Tier 1 (access to your critical systems/data) → full security assessment required. Tier 2 (limited access) → questionnaire + contract clauses. Tier 3 (no data access) → standard contract only.
- Security questionnaire essentials: Do they have ISO 27001/SOC 2? MFA on all remote access? Encryption at rest and in transit? Incident response plan? Sub-processor list?
- Contract requirements: Right to audit, mandatory breach notification within 24-48 hours, data deletion on contract end, liability clauses, minimum security standards.
- Ongoing monitoring: Vendor risk is not a one-time assessment. Annual re-assessments, continuous monitoring of vendor breach news, and prompt notification of changes.
- India context: DPDP Act 2023 requires data processors (vendors) to implement security safeguards – contracts must reflect these obligations.
- Red flag: Any vendor that refuses to complete a security questionnaire or provide audit rights is a vendor risk too high to accept.

Cyber Risk Quantification – Speaking the Board's Language

FAIR Model Basics

- FAIR (Factor Analysis of Information Risk) translates cyber risk into financial terms boards understand.
- Loss Exposure (LE) = Probable Loss Magnitude × Loss Event Frequency.
- Probable Loss Magnitude includes: Response costs, fines, revenue loss, reputational impact.
- Example: Ransomware scenario – 40% annual probability × ₹5 crore average loss = ₹2 crore annualized risk.
- ROI of controls: If MFA costs ₹10 lakh/year and reduces breach probability by 70%, the risk reduction is worth ₹1.4 crore annually – clear positive ROI.

Presenting Risk to Boards

- Use business language: 'A breach would cost ₹12-50 crore and take 3 months to recover from.'
- Show risk trends: Are we improving? What is our residual risk vs last year?
- Red/Amber/Green risk dashboard: Simple, visual, actionable.
- Benchmark: How do we compare to industry peers on key metrics?
- Ask for investment: 'Investing ₹50 lakh in EDR reduces our breach probability from 60% to 25%.'
- Board question test: 'Would our investors be comfortable if they saw this risk?'

Marriott International (Starwood Breach) ►

2018

Topic 5

What Happened

When Marriott acquired Starwood Hotels in 2016, Starwood's reservation database was already compromised – Marriott inherited the breach. Discovery came 2 years post-acquisition. Attackers had access to 500 million guest records since 2014.

Business Impact

ICO (UK) fined Marriott \$23.8M under GDPR. US Congressional hearings followed. Class action lawsuits. Exposed that M&A cyber due diligence is as critical as financial due diligence.

Key Lesson

Before acquiring ANY business, conduct thorough cyber due diligence – penetration testing, security architecture review, vulnerability assessments. Cybersecurity debt is BUSINESS debt. The price of the acquisition must account for remediation costs.

1. NIST Cybersecurity Framework 2.0 (Full Text)

Free Official Framework ▶ NIST

<https://www.nist.gov/cyberframework>

2. ISACA COBIT Framework – Governance of Enterprise IT

Framework (Free Basic Access) ▶ ISACA

<https://www.isaca.org/resources/cobit>

3. Cyber Risk Quantification – FAIR Model

Open Standard ▶ FAIR Institute

<https://www.fairinstitute.org>

4. Harvard Business Review – Cybersecurity for Business Leaders

Articles (Subscription) ▶ HBR

<https://hbr.org/topic/subject/cybersecurity>

5. SANS Institute – Reading Room (Free Research Papers)

Free Open-Source Research ▶ SANS Institute

<https://www.sans.org/reading-room/>

06

Topic 6

Safe Email Usage, Password Hygiene & Identity Protection

The three personal-level practices that prevent the majority of breaches.

Email Security Best Practices

- Email is the #1 attack vector – 94% of malware is delivered via email. Treat every unexpected email with skepticism.
- NEVER click links in unsolicited emails. Go directly to the website by typing the URL.
- Check sender domains carefully – attackers use lookalike domains: paypa1.com, support@microsoft-helpdesk.net.
- Hover over links before clicking to preview the actual URL in the status bar.
- Do NOT open attachments from unknown senders. Even .docx, .xlsx, .pdf files can contain macros/exploits.
- BEC Defense: If an email requests financial transfers, credential sharing, or urgent action – verify by phone using a KNOWN number (not the one in the suspicious email).
- Use email encryption (S/MIME or PGP) for sensitive communications. Enable DMARC/DKIM on company domains.
- Report suspicious emails to IT immediately – do NOT just delete. It helps the whole organization.

Password Hygiene & Multi-Factor Authentication

Password Best Practices

- ▶ Use passphrases: 'Coffee-Laptop-River-2024!' is more secure than 'P@ssw0rd'
- ▶ Minimum 12 characters – longer is better; 16+ recommended for critical accounts
- ▶ Unique password for EVERY account – reuse = one breach compromises all accounts
- ▶ Use a password manager: Bitwarden (free/open source), 1Password, Dashlane
- ▶ Never share passwords – not even with IT support (they don't need them)
- ▶ Change passwords immediately if breach suspected. Check haveibeenpwned.com
- ▶ Never write passwords on sticky notes or store in plain-text files/spreadsheets

Multi-Factor Authentication (MFA)

- ▶ MFA requires 2+ verification methods: something you know (password) + something you have (OTP/device) + something you are (biometric)
- ▶ Enable MFA on ALL business accounts – email, VPN, CRM, banking, cloud services
- ▶ Authenticator apps (Google Authenticator, Microsoft Authenticator, Authy) > SMS OTP (SIM swap risk)
- ▶ Hardware keys (YubiKey) = strongest form of MFA available
- ▶ MFA fatigue attack: Attackers spam MFA prompts hoping user approves accidentally – NEVER approve unexpected MFA requests
- ▶ Conditional Access: Modern MFA systems can require MFA only from unknown devices/locations

Device Security – Laptops, Phones & IoT

Laptop & Desktop Security

- Full-disk encryption mandatory: BitLocker (Windows), FileVault (Mac) – protects data if device stolen.
- Screen lock: Auto-lock after 5 minutes of inactivity – company policy minimum.
- Patch cycle: OS and software updates within 14 days of release for critical patches.
- Endpoint Detection & Response (EDR): Beyond antivirus – behavioural detection of advanced threats.
- No local admin rights: Standard users should not have admin rights on company devices.
- Mobile Device Management (MDM): Enroll all devices – enables remote wipe if lost/stolen.

Mobile & IoT Security

- Mobile: Enable biometric lock, encrypt device, enable remote wipe, use company MDM profile.
- App hygiene: Only install apps from official stores. Review permissions – does a torch app need contacts?
- IoT risk: Smart TVs, printers, building systems on corporate networks are attack vectors.
- Printer security: Printers store document copies – configure auto-delete, enable authentication to print.
- Network segregation: Put IoT devices on a separate VLAN from corporate systems.
- Default credentials: Change ALL default passwords on IoT devices immediately after setup.

Secure Use of Cloud Services & SaaS Applications

- Shared responsibility model: Cloud provider secures the PLATFORM (physical, network, hypervisor). YOU secure DATA, access management, application configuration, and user accounts.
- Shadow IT risk: 80% of employees use unauthorized SaaS apps. Unknown apps = unknown data locations = uncontrolled risk.
- SaaS due diligence before adoption: Where is data stored? Who has access? Is it GDPR/DPDP compliant? Does it support SSO and MFA?
- Access management: Apply least privilege in cloud apps – do all 500 employees need access to your AWS S3 bucket?
- Misconfiguration is the #1 cloud risk: Publicly exposed S3 buckets, overly permissive IAM roles, open storage containers – all caused by human error.
- Cloud Access Security Broker (CASB): Enterprise tool that monitors cloud app usage, enforces policy, and prevents data exfiltration to personal cloud accounts.
- Data residency: Verify where cloud providers store your data – India's DPDP Act has data localisation requirements for certain categories.
- Offboarding: When an employee leaves, immediately revoke access to all SaaS apps – not just email. This is often missed, creating ghost accounts.

Rockstar Games / GTA VI Hack ▶ 2022

What Happened

A 17-year-old hacker (Lapsus\$ group) social-engineered an employee via a WhatsApp message, obtained their Slack credentials, then accessed internal developer Slack channels and Confluence pages to steal 90 files of GTA VI development footage.

Business Impact

90 videos leaked publicly within hours. Estimated \$5M+ in competitive/reputational damage. Rockstar had to publicly confirm the breach. Developer morale impacted. The attacker was arrested but damage was permanent.

Key Lesson

Human social engineering bypasses ALL technical controls. Employee training, identity verification protocols, and MFA on all collaboration tools (Slack, Teams, Confluence) are critical. Never share credentials in any chat platform.

1. Have I Been Pwned – Check if your email/password was breached

Free Tool ▶ Troy Hunt

<https://haveibeenpwned.com>

2. Bitwarden – Free Open-Source Password Manager

Free Tool ▶ Bitwarden Inc.

<https://bitwarden.com>

3. Google Safety Center – Password Checkup

Free Tool ▶ Google

<https://safety.google>

4. NCSC (UK) – Password Guidance: Simplifying Your Approach

Free Official Guide ▶ NCSC UK

<https://www.ncsc.gov.uk/collection/passwords>

5. CISA – MFA How-To Guide for Business

Free Guide ▶ CISA

<https://www.cisa.gov/mfa>

SESSION 3

Sunday, 31 May 2026
10:00 AM - 1:00 PM

Topics Covered: 7 · 8 · 9

Data Protection | Remote Work Security | Employee Role in Cyber Defence

07

Topic 7

Data Protection Principles & Secure Handling of Sensitive Information

Classification, storage, transmission, and disposal of sensitive data – the business imperative.

Data Classification & Sensitivity Levels

- Data classification is the foundation of data protection. You cannot protect what you cannot identify.
- Public: Information intended for public disclosure. No special handling required. (e.g. Marketing brochures, press releases).
- Internal / Confidential: For internal use only. Not for public release. (e.g. Internal memos, operational procedures, org charts).
- Sensitive / Restricted: High business impact if disclosed. Limited distribution. (e.g. Financial reports, HR records, legal contracts, M&A plans).
- Highly Confidential / Secret: Critical business impact if disclosed; regulatory obligations. (e.g. Customer PII, patient records, trade secrets, R&D).
- Classification responsibilities: Every employee who creates or handles data must classify it. Not just IT – legal, HR, finance, operations all create sensitive data daily.

Building a Data Inventory – Know Your Data

- You cannot protect what you cannot find. A data inventory (or data map) is the foundation of data governance.
- Data inventory captures: What personal data you hold, where it lives (system/location), who has access, how it flows, legal basis for processing, and retention period.
- Common data locations: CRM, HRMS, ERP, email servers, SharePoint/Drive, employee laptops, physical files, third-party SaaS apps, analytics platforms.
- Data flows: Know how data moves – from collection point, through processing systems, to third parties, and eventually deletion.
- DPDP/GDPR requirement: Maintaining a Record of Processing Activities (ROPA) is legally required for organizations processing significant personal data.
- Data minimisation audit: For each category of data you hold, ask – do we NEED this? If not, delete it. Less data = less liability.
- Retention schedule: Define how long each data category is kept – invoices (7 years per IT Act), employee records (post-departure), customer data (active + X years), marketing data (consent-based).
- Action: Conduct a data discovery workshop across HR, Finance, Legal, Marketing, and IT – most organizations are surprised by what they find.

Secure Data Handling Practices

Storage Best Practices

- Encrypt data at rest – AES-256 is the gold standard; never store sensitive data in plain text
- Access control – Only authorized individuals should access sensitive data (least privilege)
- Avoid storing sensitive data on personal devices, USB drives, or personal cloud accounts
- Use company-approved cloud storage (SharePoint, Google Workspace Enterprise, AWS S3 with encryption) – not personal Dropbox/Gmail
- Database security – Sensitive fields encrypted separately; no direct database access for non-DBAs
- Secure backup – 3-2-1 rule: 3 copies, 2 media types, 1 offsite/offline

Transmission & Disposal

- Encrypt data in transit – use HTTPS, TLS 1.3, SFTP – NEVER send sensitive data over HTTP or plain FTP
- Use secure email (encrypted email) for sensitive attachments – not standard email
- File sharing – Use access-controlled platforms with expiry links; avoid email attachments for large sensitive files
- Print & Paper – Secure printing (badge-release), locked cabinets, clear-desk policy
- Data retention – Delete data when no longer needed; do NOT hoard data indefinitely
- Secure disposal – Wipe hard drives (DoD 5220.22-M standard); shred physical documents; destroy old storage media

Data Loss Prevention (DLP) – Stopping Data from Leaving

What DLP Does

- Monitors and controls data movement across email, web, USB, print, and cloud.
- Detects sensitive data patterns: Aadhaar numbers, credit cards, PAN, medical records.
- Blocks unauthorized transfers: Cannot email 5,000 customer records without approval.
- Endpoint DLP: Prevents copying sensitive files to USB or personal cloud.
- Network DLP: Inspects data leaving the network – catches data in transit.
- Cloud DLP: Monitors data uploaded to cloud storage and collaboration tools.

DLP in Practice

- Policy creation: Define what is sensitive, who can send it, and where it can go.
- False positives: Overly aggressive DLP blocks legitimate business – tuning is critical.
- Employee communication: Staff must understand WHY these controls exist – not feel spied on.
- Incident response: DLP generates alerts – who reviews and acts on them?
- India context: DPDP Act creates legal obligation to prevent unauthorised disclosure of personal data.
- Quick win: Even basic DLP to block emailing large spreadsheets to personal addresses prevents most accidental breaches.

Facebook (Meta) Cambridge Analytica ► 2018

What Happened

Cambridge Analytica harvested personal data of 87 million Facebook users without explicit consent through a third-party quiz app. Data was used for political ad targeting. Facebook allowed third-party apps excessive access to user friend networks without user knowledge.

Business Impact

Facebook fined \$5 billion by FTC – largest FTC fine in history at the time. Parliamentary investigations in UK, EU, US. GDPR triggered. CEO Mark Zuckerberg testified before Congress. Led to global re-evaluation of data sharing practices.

Key Lesson

Data you collect is a liability, not just an asset. Minimize data collection (only collect what you need). Implement strict third-party data-sharing controls. Privacy-by-Design must be embedded in every product, not an afterthought.

1. ISO 27001 Information Security Standard – Overview

International Standard ▶ ISO.org

<https://www.iso.org/isoiec-27001-information-security.html>

2. GDPR Official Text & Guidelines

Regulation (Free) ▶ EUR-Lex / EU

<https://gdpr-info.eu>

3. NIST SP 800-53 – Security Controls Catalog

Free Standard ▶ NIST

<https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>

4. OWASP Data Classification Guide

Free Open-Source Guide ▶ OWASP Foundation

https://owasp.org/www-community/Data_Classification

5. Privacy Rights Clearinghouse – Data Broker & Breach Database

Free Database ▶ PRC

<https://privacyrights.org>

08

Topic 8

Remote Work & Digital Workplace Security Best Practices

The home office is now the corporate perimeter – securing it is everyone's responsibility.

Remote Work Has Expanded the Attack Surface

- Pre-2020: Corporate network had a defined perimeter – firewall protected inside vs outside. Remote work dissolved this perimeter permanently.
- Home networks: Consumer-grade routers, default passwords, unpatched firmware, shared with personal devices, smart TVs, IoT gadgets.
- Personal devices (BYOD): May lack endpoint protection, encryption, MDM (Mobile Device Management) controls.
- Public Wi-Fi: Airports, cafes, hotels – unencrypted, susceptible to man-in-the-middle attacks, fake hotspots ('Evil Twin' attacks).
- Shadow IT surge: Employees adopt their own tools for productivity – Trello, WhatsApp, personal Dropbox – outside IT oversight.
- Cloud apps: Accessing corporate SaaS apps from unmanaged devices bypasses DLP (Data Loss Prevention) controls.
- Insider risk increases: Less supervision means higher risk of accidental or intentional data exfiltration.

Securing Your Remote Work Environment

Home Network & Device Security

- ▶ Change default router password; use WPA3 or WPA2 encryption
- ▶ Separate work and personal traffic – use a dedicated work VLAN or device
- ▶ Keep router firmware updated – check manufacturer's website regularly
- ▶ Always use company VPN when accessing corporate systems remotely
- ▶ Use company-issued devices or ensure personal devices meet security standards
- ▶ Enable full-disk encryption on laptops (BitLocker/FileVault)
- ▶ Lock screen when stepping away – even at home (Windows+L)
- ▶ Use an up-to-date antivirus/EDR (Endpoint Detection & Response) solution

Video Calls & Collaboration Tools

- ▶ Use unique meeting IDs and passwords for every Zoom/Teams meeting
- ▶ Enable waiting rooms for external participants
- ▶ Never share meeting links on public social media
- ▶ Beware screen sharing – ensure no sensitive data is visible before sharing
- ▶ Secure your background – whiteboards with company info, documents visible
- ▶ Deepfake voice/video attacks are real – verify unexpected requests by secondary channel
- ▶ Use company-approved messaging only (Teams/Slack) – NOT personal WhatsApp for work data
- ▶ Log out of all platforms after sessions on shared/personal computers

Zero Trust Architecture – Never Trust, Always Verify

Zero Trust Principles

- Assume breach: Design as if the attacker is already inside your network.
- Verify explicitly: Every access request authenticated, authorized, and encrypted – regardless of location.
- Least privilege access: Users get minimum access needed for their role, nothing more.
- Micro-segmentation: Divide networks into small zones – breach of one zone doesn't compromise all.
- Continuous validation: Trust is not static – re-verify based on user behaviour, device health, location.
- Inspect all traffic: Even internal network traffic is inspected and logged.

Zero Trust for Remote Work

- Identity is the new perimeter: Who you are (verified identity) matters more than where you are (office vs home).
- Conditional access: MFA required from unknown devices or locations; blocked from high-risk countries.
- Device health checks: Only managed, patched, compliant devices can access corporate resources.
- ZTNA (Zero Trust Network Access): Replaces VPN – grants access per-application, not full network.
- Privileged Access Workstations (PAWs): Dedicated hardened devices for IT admins only.
- Business benefit: Zero trust reduces breach blast radius – even if one account is compromised, attacker cannot move laterally.

Securing Hybrid & Multi-Cloud Environments

- Hybrid reality: Most organizations run a mix of on-premises servers, private cloud, AWS/Azure/GCP, and dozens of SaaS applications – security must span all.
- Identity federation: Single Sign-On (SSO) with MFA across all platforms reduces password fatigue and centralizes access control.
- Cloud security posture management (CSPM): Automated tools continuously check cloud configurations against security best practices and alert on misconfigurations.
- Secrets management: API keys, database passwords, and certificates should be stored in a vault (HashiCorp Vault, AWS Secrets Manager) – NEVER in code or emails.
- Container security: Docker and Kubernetes environments require image scanning, network policies, and runtime protection – often overlooked by fast-moving dev teams.
- Logging & monitoring: Centralize logs from all environments in a SIEM (Security Information and Event Management) for correlation and anomaly detection.
- Incident response across clouds: Your IR plan must cover how you respond in AWS vs Azure vs on-prem – different tools, different forensics processes.
- Multi-cloud data sovereignty: Understand where each cloud provider processes and stores data – critical for DPDP Act and GDPR compliance.

Twitter (X) Internal Systems Hack ► 2020

What Happened

Hackers called Twitter employees posing as IT support staff. They convinced employees to provide VPN credentials via a fake internal portal. Attackers accessed Twitter's admin tools and hijacked accounts of Barack Obama, Joe Biden, Bill Gates, Elon Musk, and Apple to run a Bitcoin scam.

Business Impact

\$120,000+ in Bitcoin stolen within hours. Twitter disabled all verified account tweeting globally for hours. Massive media coverage. Three teenagers charged. Twitter's reputation for security severely damaged. Led to full remote-access audit.

Key Lesson

Social engineering via phone is as dangerous as technical hacking. Remote employees must be trained to verify all IT requests through official channels. Companies need strict protocols: IT will NEVER ask for your password. Zero-trust remote access policies are essential.

1. CISA – Remote Work Cybersecurity Guide

Free Official Guide ▶ CISA

<https://www.cisa.gov/topics/physical-security/telework>

2. NCSC UK – Home Working: Preparing Your Organisation

Free Guide ▶ NCSC UK

<https://www.ncsc.gov.uk/guidance/home-working>

3. Zero Trust Architecture – NIST SP 800-207

Free Standard ▶ NIST

<https://csrc.nist.gov/publications/detail/sp/800-207/final>

4. EFF Surveillance Self-Defense Guide

Free Open-Source Guide ▶ Electronic Frontier Foundation

<https://ssd.eff.org>

5. OpenVPN – Understanding VPN Technology

Free Educational Resource ▶ OpenVPN

<https://openvpn.net/community-resources/>

Topic 9

Role of Employees in Preventing & Reporting Cyber Incidents

Every employee is a security sensor – and a potential attack vector. Culture is your strongest control.

The Human Element – Your Last Line of Defence

- 82% of breaches involve a human element (Verizon DBIR 2024). Technology alone cannot stop attacks that exploit trust, urgency, and authority.
- Security awareness training reduces phishing susceptibility by 75% (KnowBe4, 2023). The ROI of training is measurable.
- Employees are targets because they have: system access, knowledge of processes, trust from colleagues, ability to make financial decisions.
- Social Engineering Tactics: Pretexting (fabricated scenario), Baiting (curiosity/greed), Quid Pro Quo (offering help in exchange for access), Tailgating (physical access by following authorized person).
- Authority bias: Attackers impersonate CEOs, regulators, IT, or police to create pressure. Always verify unexpected requests – even from senior leadership.
- Urgency is a red flag: 'Act NOW or your account will be closed!' – legitimate organizations don't demand immediate, unverifiable action.

Prevention vs. Response – Every Employee's Responsibility

Prevention (Daily Habits)

- Think before you click – hover over links, scrutinize sender address
- Lock screens when away from desk – even for 2 minutes
- Follow clean desk policy – no sensitive documents left visible
- Use only approved software – report Shadow IT to IT department
- Don't plug in unknown USB drives – they may be loaded with malware
- Verify requests for sensitive data or payments via alternative channel
- Keep software updated – promptly apply patches when prompted
- Protect physical access – don't hold doors for strangers (tailgating)

Incident Reporting (What & How)

- REPORT immediately: Suspicious emails, unexpected login alerts, slow/unusual device behavior, unauthorized data access, lost/stolen devices
- Reporting channel: Know your company's incident reporting process – IT helpdesk, CISO, dedicated security email, SIEM alert button
- No-blame culture: Report even if you clicked the phishing link. Early reporting limits damage exponentially
- Document everything: Time, what happened, what you did – for forensics
- Isolate don't investigate: If you suspect compromise, disconnect from network; don't try to fix it yourself
- Post-incident learning: Participate in after-action reviews; share lessons

Building a No-Blame Security Culture – Reporting Without Fear

Why People Don't Report

- Fear of punishment: 'I clicked the phishing link – will I be fired?'
- Embarrassment: 'I should have known better – I'll sort it out myself.'
- Don't know how: Incident reporting process is unclear or too complex.
- Denial: 'Maybe it was nothing – I don't want to cause a fuss.'
- Past experience: They reported before and nothing happened, or were blamed.
- Culture signal: If leadership punishes reporters, everyone learns to stay silent.

Creating the Right Culture

- Policy first: Written, visible commitment that reporting is safe and rewarded.
- Leadership modeling: CEO publicly praises an employee who reported a phishing attempt.
- Simple reporting: One button in email client, one number to call, one address to email.
- Fast feedback: Acknowledge reports within 1 hour; tell reporters what happened.
- Celebrate catches: 'Phishing Hero of the Month' – public recognition for reporting.
- Anonymous option: Some will only report if guaranteed anonymity – provide this channel.

Security Awareness Training That Actually Works

- Annual compliance e-learning DOES NOT WORK: 70% of information forgotten within 24 hours (Ebbinghaus Forgetting Curve). Checkbox training creates checkbox behaviour.
- What works: Micro-learning (5-minute monthly modules), simulated phishing exercises, scenario-based training, just-in-time learning triggered by real incidents.
- Phishing simulations: Send fake phishing emails to all employees – those who click get immediate remedial training, not punishment. Click rates should decrease over time.
- Role-based training: Finance teams train on BEC and wire fraud. HR trains on data handling. Developers train on secure coding. Generic training = ignored training.
- Metrics that matter: Phishing click rate (target <5%), training completion rate (target 100%), mean time to report suspicious activity, policy quiz pass rate.
- Gamification: Security escape rooms, capture-the-flag events, points-based security challenges – learning through play increases retention by 40%.
- Manager involvement: Security training delivered or endorsed by the employee's own manager has 3x higher completion and retention rates.
- Frequency: Touch points every month – monthly tip, quarterly simulation, bi-annual deep training, annual policy acknowledgement.

Ubiquiti Networks Insider Threat ▶ 2021

What Happened

A senior Ubiquiti engineer and former employee used his admin access to clone the company's GitHub repositories, stole gigabytes of files, then extorted the company for ~\$2M in Bitcoin while simultaneously leaking data and posing as an anonymous whistleblower to damage stock price.

Business Impact

Ubiquiti's stock fell 20% (market cap loss ~\$4B). Investigation by FBI. Employee was sentenced to 6 years in prison. Exposed that privileged insiders with too much access and poor offboarding controls are a critical risk even at major tech companies.

Key Lesson

Access control and least privilege are essential – even for senior staff. Regular access reviews, audit logs for privileged user activity, and robust offboarding (immediate access revocation) would have prevented or quickly detected this. Trust but verify.

1. KnowBe4 Security Awareness Training – Free Resources

Free Training Materials ▶ KnowBe4

<https://www.knowbe4.com/free-it-security-tools>

2. SANS Security Awareness Work-from-Home Deployment Kit

Free Resource Kit ▶ SANS Institute

<https://www.sans.org/security-awareness-training/resources/>

3. Social Engineering Red Flags Poster (Printable)

Free Awareness Material ▶ StaySafeOnline.org

<https://staysafeonline.org>

4. Open Security Training 2 – Free Video Courses

Free Online Courses ▶ OpenSecurityTraining2

<https://ost2.fyi>

5. CERT Insider Threat Center – Carnegie Mellon

Free Research ▶ SEI/CMU

<https://www.cisa.gov/topics/physical-security/insider-threat-mitigation>

SESSION 4

Sunday, 7 June 2026
10:00 AM - 1:00 PM

Topics Covered: 10 · 11 · 12

Privacy & Compliance | Organizational Policies | Building a Cyber-Secure Culture

10

Topic 10

Introduction to Privacy, Compliance & Data Protection Regulations

The legal framework around data – what organizations must do, and the cost of non-compliance.

Key Data Protection Regulations – Global Overview

- GDPR (EU/UK – 2018): Strictest privacy law globally. Applies to ANY org processing EU citizen data. Rights include: access, erasure ('right to be forgotten'), portability. Fines up to 4% of global turnover or €20M.
- CCPA/CPRA (California, USA – 2020/2023): Rights to know, delete, opt out of sale. Applies to businesses with \$25M+ revenue or 100K+ consumers. Fines up to \$7,500 per intentional violation.
- PDPB / DPDP Act (India – 2023): India's Digital Personal Data Protection Act. Applies to all digital personal data processed in India. Penalties up to ₹250 crore per breach.
- HIPAA (USA Healthcare): Protects patient health information. Fines up to \$1.9M per violation category per year.
- PCI DSS v4.0 (Payment Cards): Mandatory for all entities processing card payments. 12 core requirements; non-compliance = loss of card processing rights.
- ISO 27001: International standard for Information Security Management Systems. Not mandatory, but gold-standard for demonstrating security posture.

Privacy Principles Every Business Must Follow

Core Privacy Principles (GDPR-Based)

- Lawfulness – Must have a legal basis to process personal data (consent, contract, legal obligation, legitimate interest)
- Purpose Limitation – Data collected for one purpose cannot be used for unrelated purposes
- Data Minimisation – Collect only what is strictly necessary for the stated purpose
- Accuracy – Keep personal data accurate and up to date; delete inaccurate data
- Storage Limitation – Don't keep data longer than necessary; define retention periods
- Integrity & Confidentiality – Process data securely to prevent unauthorized access
- Accountability – Document your compliance; be able to demonstrate it to regulators

Individual Rights (GDPR / DPDP)

- Right to Access – Individuals can request all data you hold on them
- Right to Erasure – 'Right to be forgotten'; delete data on request (with exceptions)
- Right to Portability – Provide data in machine-readable format for transfer
- Right to Object – Opt out of direct marketing, profiling, automated decisions
- Right to Rectification – Correct inaccurate personal data
- Right to Restrict Processing – Pause processing while accuracy dispute is resolved
- Right to Human Review – Challenge automated/AI decisions affecting individuals

Conducting a Privacy Impact Assessment (PIA / DPIA)

- What is a PIA: A systematic process to identify and minimize privacy risks before launching a new product, process, or system that handles personal data.
- When required: New product collecting personal data, new vendor relationship, change in data use purpose, AI/profiling systems, large-scale processing of sensitive data.
- PIA Step 1 – Describe the processing: What data, whose data, how collected, how used, who has access, where stored, how long kept.
- PIA Step 2 – Assess necessity: Is all data collected strictly necessary? Can you achieve the same goal with less or anonymized data?
- PIA Step 3 – Identify risks: What could go wrong? Unauthorized access, inaccurate data, function creep, secondary use without consent.
- PIA Step 4 – Mitigate risks: What technical and organizational controls reduce each identified risk to acceptable level?
- PIA Step 5 – Document & approve: Record the assessment, mitigation decisions, and residual risk. DPO/legal sign-off before go-live.
- Business culture shift: Privacy is a design input, not a legal afterthought. Build it into project kick-off checklists alongside financial planning.

India's DPDP Act 2023 – What Businesses Must Know

Key Requirements

- Applies to all digital personal data processed in India, and data of Indian citizens processed abroad.
- Data Principal rights: Right to access, correction, erasure, and grievance redressal.
- Consent: Must be informed, specific, unconditional, and easily withdrawable.
- Data Fiduciary obligations: Purpose limitation, data minimization, accuracy, retention limits, security safeguards.
- Data Protection Board: New regulatory authority to receive complaints and levy penalties.
- Significant Data Fiduciaries (SDFs): High-risk entities subject to enhanced obligations including a DPO and independent audit.

Penalties & Business Impact

- Penalties up to ₹250 crore per breach incident – among the highest globally relative to GDP.
- ₹200 crore for failure to notify breach to Data Protection Board and affected individuals.
- ₹50 crore for non-compliance with obligations for children's data.
- Cross-border transfer: Government to specify which countries are permitted for data transfer.
- Action required NOW: Data inventory, consent mechanism review, privacy notice update, DPO appointment (if SDF), vendor contract update, breach notification process.
- India context: Every business holding customer, employee, or partner data is a Data Fiduciary – compliance is not optional.',

British Airways GDPR Fine ► 2020

What Happened

British Airways suffered a cyberattack that compromised personal data of 429,612 customers including names, addresses, payment card numbers, and CVV codes. Root cause was a Magecart-style script injected into their booking website that skimmed card data in real time.

Business Impact

UK ICO (Information Commissioner's Office) initially proposed a £183M fine – the first major GDPR fine under GDPR. Final fine was £20M due to COVID. BA paid £10M additional in legal costs. Reputation severely impacted. Led to complete security overhaul.

Key Lesson

Web application security is a privacy obligation under GDPR. Regular security audits, third-party script monitoring, and Content Security Policy (CSP) implementation are not optional for any business that processes payments online.

1. GDPR Official Text & Recitals

Free Official Regulation ▶ EUR-Lex

<https://gdpr-info.eu>

2. India DPDP Act 2023 – Official Text

Official Act ▶ MeitY India

<https://www.meity.gov.in/data-protection-framework>

3. ICO UK – Practical GDPR Guides for Business

Free Guides ▶ ICO UK

<https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/>

4. PCI Security Standards Council – Official Resources

Free Resources ▶ PCI SSC

<https://www.pcisecuritystandards.org>

5. IAPP Privacy Resource Center – Free Guides & Templates

Free Resources ▶ IAPP

<https://iapp.org/resources/article/privacy-resources-for-gdpr/>

11

Topic 11

Understanding Organizational Cybersecurity Policies & Responsibilities

The governance structures and policies that translate strategy into daily secure behaviour.

Essential Cybersecurity Policies Every Organization Needs

- Information Security Policy (ISP): Master policy defining organization's approach to security; scope, responsibilities, principles. Foundation of all other policies.
- Acceptable Use Policy (AUP): What employees can/cannot do with company devices, networks, data, and internet access. Basis for disciplinary action if violated.
- Access Control Policy: How access is granted, reviewed, and revoked. Password requirements, MFA mandates, privileged access management.
- Incident Response Policy: Step-by-step process for detecting, containing, eradicating, recovering, and learning from security incidents.
- Data Classification & Handling Policy: How to classify, store, transmit, and dispose of data at each sensitivity level.
- BYOD (Bring Your Own Device) Policy: Rules for using personal devices for work. MDM enrollment, minimum security requirements, remote wipe consent.
- Vendor / Third-Party Security Policy: Security requirements for vendors; security questionnaires, contract clauses, audit rights.

Roles & Responsibilities in Organizational Cybersecurity

Governance Structure

- Board / Senior Leadership – Set risk appetite, approve security budget, receive regular cyber risk reports
- CISO (Chief Information Security Officer) – Owns security strategy, program, and compliance
- CIO / IT Director – Technology infrastructure security and operational security controls
- DPO (Data Protection Officer) – Mandatory under GDPR for many organizations; owns privacy compliance
- Legal & Compliance – Regulatory adherence, contract review for security clauses, breach notification
- HR – Security in employment lifecycle: onboarding training, background checks, offboarding access revocation
- Finance – Cyber risk in financial planning, AP fraud prevention, wire transfer verification

Every Employee's Responsibilities

- Complete mandatory security awareness training – ANNUALLY at minimum
- Read and acknowledge all security policies – and actually follow them
- Report security incidents immediately without fear of blame
- Protect access credentials – never share accounts or passwords
- Follow data classification and handling rules for all data you create or use
- Use only approved software and services – no Shadow IT
- Understand that security is everyone's role – not just IT's responsibility
- Participate in security drills and phishing simulation exercises

Patch Management – The Single Most Effective Control

- Reality check: 60% of breaches exploit vulnerabilities for which a patch had been available for over a year (Ponemon, 2024). Patching is the highest-ROI security activity.
- Patch categories: Critical (deploy within 24-72 hours), High (within 7 days), Medium (within 30 days), Low (within 90 days).
- Scope: OS patches, application patches, firmware updates (routers, firewalls, printers), cloud workloads, containers.
- Patch management process: Inventory → test patch in non-production → deploy to staging → pilot group → full production → verify.
- Risk of not testing: A poorly tested patch once caused 8.5 million Windows devices to crash globally (CrowdStrike, July 2024) – demonstrating that patch processes need testing too.
- Compensating controls when patching is not possible: Network segmentation, web application firewall (WAF), additional monitoring on unpatched systems.
- Legacy systems: Define a risk acceptance process for systems that cannot be patched – compensating controls, isolation, and documented risk acceptance by management.
- Metrics: Patch compliance rate by criticality (target: 100% critical within 72 hours), mean time to patch, percentage of assets with known critical vulnerabilities.

Incident Response Planning – Be Ready Before the Breach

Incident Response Plan Components

- Preparation: IR team roles, contact list, playbooks, legal retainer, insurance contacts, communication templates.
- Identification: How do we know we've been breached? SIEM alerts, user reports, ransom note, partner notification.
- Containment: Short-term (isolate system) and long-term (rebuild with clean backup) containment strategies.
- Eradication: Remove malware, close entry points, rotate all compromised credentials.
- Recovery: Restore from clean backups, test systems, monitor for re-infection.
- Lessons Learned: Post-incident review within 2 weeks – root cause, timeline, what worked, what didn't.

Tabletop Exercise – Your Playbook

- What: A facilitated simulation where leadership walks through a breach scenario in a room – no systems involved.
- Why: Reveals gaps in your plan before a real incident. Builds muscle memory for decision-making under pressure.
- Frequency: Quarterly for IT/security team; bi-annual for executive team; annual full organization.
- Sample scenario: 'It is 6 AM Monday. Your CISO calls – ransomware has encrypted 70% of your file servers. Backups are offline. The attacker demands \$3M. What do you do?'
- Test these questions: Who authorizes public communication? When do we call law enforcement? Who has board notification authority? Is our IR retainer contract active?
- Output: Updated IR plan, trained team, known gaps addressed before a real incident.

Equifax Data Breach ► 2017

What Happened

Attackers exploited a known Apache Struts vulnerability (CVE-2017-5638) that Equifax's IT had failed to patch for 2 months after a patch was available. An expired SSL certificate also meant network monitoring had been blind for 19 months. 147 million people's data stolen.

Business Impact

Equifax paid \$700M+ in settlements. FTC fine of \$575M. CEO, CIO, and CSO all resigned. Stock dropped 35%. Credit monitoring offered to half the US population. Led to sweeping changes in credit bureau regulation and cybersecurity standards.

Key Lesson

Patch management and vulnerability management are not IT tasks – they are board-level risk management priorities. A known, patchable vulnerability destroyed a Fortune 500 company's reputation and cost nearly \$1 billion. Governance failures, not just technical ones, cause the biggest breaches.

1. **SANS Policy Templates – 40+ Free Security Policy Templates**
Free Template Library ▶ SANS Institute

<https://www.sans.org/information-security-policy/>

2. **ISO/IEC 27002:2022 – Code of Practice for Security Controls**
International Standard ▶ ISO

<https://www.iso.org/standard/75652.html>

3. **CIS Controls v8 – Free Security Controls Framework**
Free Open-Source Framework ▶ Center for Internet Security

<https://www.cisecurity.org/controls>

4. **NIST SP 800-100 – Information Security Handbook for Managers**
Free Publication ▶ NIST

<https://csrc.nist.gov/publications/detail/sp/800-100/final>

5. **Cyber Essentials (UK) – Government-Backed Certification Scheme**
Free Guidance ▶ NCSC UK / IASME

<https://www.ncsc.gov.uk/cyberessentials/overview>

12

Topic 12

Building a Culture of Shared Cyber Accountability Across Business Teams

Technology and policy only work when culture supports them – the human operating system of security.

What Is a Cyber-Secure Culture?

- A cyber-secure culture exists when security-conscious behaviour is natural, habitual, and expected across ALL teams – not just IT.
- Security culture maturity model: Absent → Aware → Compliant → Proactive → Ingrained. Most organizations sit at Compliant. World-class organizations reach Ingrained.
- Signs of a strong security culture: Employees voluntarily report phishing, teams raise security concerns in project planning, leaders model secure behavior, security is celebrated not feared.
- Signs of a weak security culture: Security bypassed for convenience, incidents go unreported, training is checkbox exercise, blame follows incidents.
- Culture change starts at the top: Board and C-suite must visibly champion and model cybersecurity behaviors. Security must be a stated organizational value.
- Gamification works: Phishing simulations with points, security champion programs, bug bounty programs, and incident recognition all build culture.

AI & Automation in Cybersecurity Defence

How AI Helps Defenders

- Anomaly detection: AI learns normal behaviour patterns and flags deviations – detects novel attacks signature-based tools miss.
- Threat intelligence: AI correlates millions of threat feeds, dark web data, and indicators of compromise – human analysts cannot process this volume.
- Automated response (SOAR): Security Orchestration, Automation and Response platforms automatically contain threats (block IP, quarantine device) without human delay.
- User & Entity Behaviour Analytics (UEBA): Detects insider threats by flagging unusual user actions – large downloads at 2AM, login from new country.
- Vulnerability prioritization: AI risk-scores thousands of vulnerabilities to tell teams which to patch FIRST based on exploitability and business impact.

Responsible AI in Security

- AI is not infallible: False positives create alert fatigue – analysts begin ignoring alerts. Tuning is continuous work.
- Adversarial AI: Attackers also use AI – to craft better phishing, bypass AI-based defences, and accelerate attack timelines.
- Explainability: AI decisions in security must be explainable – why was this user flagged? Black-box AI in security creates legal and operational risk.
- Data privacy in security AI: AI systems trained on employee behaviour data raise significant privacy and DPDP compliance considerations.
- Human-in-the-loop: AI should augment, not replace, human security analysts for high-stakes decisions.
- Start small: AI-powered email filtering and EDR are good starting points – mature organizations add SIEM + SOAR + UEBA.

Building & Sustaining Cyber Accountability

Building the Culture

- Security Champions Program: Appoint a voluntary security advocate in each business unit – not a full-time security role, but a bridge between teams and IT
- Regular training – Move beyond annual compliance e-learning; use simulated phishing, tabletop exercises, lunch-and-learns
- Clear escalation paths – Every employee must know exactly how to report; make it frictionless
- Positive reinforcement – Recognize and reward secure behavior publicly; send 'phishing hero' shout-outs
- Leadership modeling – If the CEO bypasses security controls, everyone will follow
- Onboarding – Security training from day one; not month three

Sustaining Accountability

- Metrics that matter: % phishing click rate (target <5%), training completion, mean time to report incidents, policy violation trends
- Tabletop exercises: Quarterly simulation of breach scenarios for leadership – what would we do if ransomware hit today?
- Third-party audit: External penetration testing and security assessments validate effectiveness and identify gaps
- Continuous awareness: Monthly security tips, digital signage, Slack/Teams security bot reminders – keep security visible
- After-action reviews: Every incident becomes a learning opportunity – no blame, full transparency on root cause
- Board reporting: Monthly security dashboard to leadership; normalize cyber risk as business risk

The CISO-Business Partnership – Security as a Business Enabler

From Gatekeeper to Business Partner

- Old model: Security says 'No' to everything. Business sees security as a blocker.
- New model: Security says 'Here is how we can do it securely.' Business sees security as an enabler.
- Business-aligned CISO: Presents risk in financial terms, understands business objectives, prioritizes controls that protect revenue.
- Risk-based decisions: Not every system needs the same protection level – protect crown jewels first.
- Security enabling business: SOC 2 certification wins enterprise customers. GDPR compliance unlocks EU market. Strong security posture enables M&A activity.
- Speed vs security: DevSecOps integrates security in development pipelines – faster, not slower.

Building the CISO-Board Relationship

- Regular board reporting: Monthly 1-page security dashboard – risk posture, top threats, control effectiveness, incidents.
- Board education: Run a cyber risk workshop for board members annually – they cannot govern what they don't understand.
- Security committee: Establish a board-level security or risk committee with executive accountability.
- Budget conversation: Security ROI is hard to measure (prevention is invisible). Quantify risk reduction using FAIR model.
- CISO access: CISO must have direct access to board and CEO – not buried under CTO with filtered communication.
- Success metric: Board asks proactively about cyber risk at every meeting – culture change achieved.

Cybersecurity Metrics That Matter – Measuring Culture & Posture

- Phishing click rate: Percentage of simulated phishing emails clicked. Industry target: <5%. Benchmark your team, track improvement over time.
- Training completion rate: % of mandatory security training completed on time. Target: 100%. Non-completion correlates with higher breach probability.
- Mean Time to Detect (MTTD): How long before an intrusion is identified? Global average: 204 days. Target: <24 hours with good SIEM/EDR.
- Mean Time to Respond (MTTR): How quickly is a confirmed incident contained? Target: <4 hours for critical systems.
- Patch compliance rate: % of critical vulnerabilities patched within SLA. Target: 100% critical within 72 hours.
- Vulnerability density: Number of critical/high vulnerabilities per asset. Track trend – are we getting better or worse?
- Security incident trend: Month-over-month number of security incidents by severity. Increasing trend = deteriorating posture.
- Policy exception rate: How many formal exceptions to security policy are open? High numbers = culture of bypassing controls.

Microsoft Security Culture Transformation ► 2002–Present

Topic 12

What Happened

After worms (Code Red, Nimda) crippled the internet using Windows vulnerabilities, Bill Gates issued his famous 'Trustworthy Computing' memo in 2002. Microsoft halted all Windows development for 2 months for security training. Created the Security Development Lifecycle (SDL) – security-by-default in software design.

Business Impact

Microsoft transformed from the most-patched software company to a security industry leader. SDL became an industry standard adopted by hundreds of companies. Microsoft now earns \$20B+ in security revenue annually. Demonstrated that culture change at scale is possible and profitable.

Key Lesson

Security culture transformation requires executive commitment, investment in training, and willingness to delay business for security. The short-term cost of Microsoft's 2-month freeze was vastly outweighed by the long-term brand trust and security revenue gained. Security is a competitive advantage.

1. Cybrary – Free Cybersecurity Courses for All Levels

Free Learning Platform ▶ Cybrary

<https://www.cybrary.it/catalog/cybersecurity/>

2. OWASP Top 10 – Most Critical Web Application Security Risks

Free Open-Source Guide ▶ OWASP Foundation

<https://owasp.org/Top10/>

3. TryHackMe – Beginner-Friendly Cybersecurity Labs

Free Tier Available ▶ TryHackMe

<https://tryhackme.com>

4. Coursera – Google Cybersecurity Professional Certificate

Paid Course / Financial Aid Available ▶ Google / Coursera

<https://www.coursera.org/professional-certificates/google-cybersecurity>

5. DarkReading – Free Cybersecurity News & Analysis

Free Industry Media ▶ Dark Reading

<https://www.darkreading.com>

Course Summary – Key Takeaways

1-3

Fundamentals, Threats & Attacks

Cybersecurity is everyone's responsibility. Phishing, malware & ransomware cause 90%+ of incidents. Patch promptly.

4-6

Business Impact, Risk & Safe Practices

Breaches cost millions. Every business decision has a cyber dimension. MFA + strong passwords stop most attacks.

7-9

Data Protection, Remote Work & People

Classify and encrypt your data. Secure your home office. Report incidents immediately – no blame, full speed.

10-12

Compliance, Policy & Culture

GDPR/DPDP are legal obligations. Policies only work if culture supports them. Security is a competitive advantage.

Your 90-Day Cybersecurity Action Plan – For Business Leaders

- WEEK 1: Conduct a basic security audit – identify all systems, data locations, vendors with access, and current controls. What do you have? What is missing?
- WEEK 2-4: Enable MFA on ALL accounts (email, VPN, cloud services, banking). This single step prevents 99.9% of account takeover attacks.
- MONTH 1: Confirm your backup strategy – test recovery from backup this week. If you cannot restore, your backup is not a backup.
- MONTH 1: Launch phishing awareness training – run a simulated phishing exercise to establish your baseline click rate.
- MONTH 2: Update vendor contracts – add security clauses, breach notification requirements, and audit rights to your top 10 vendor agreements.
- MONTH 2: Conduct a patch audit – identify all critical and high vulnerabilities across your estate and create a remediation plan with owners and deadlines.
- MONTH 3: Develop or test your Incident Response Plan – run a tabletop exercise with your leadership team.
- MONTH 3: Report to your board – present your cybersecurity posture, top risks, and improvement plan. Make cyber a permanent board agenda item.

The 12 Non-Negotiables – Every Business Must Have These

Technical Controls

1. MFA on ALL accounts – no exceptions for any user or system.
2. Endpoint Detection & Response (EDR) on all devices.
3. Regular, tested, offline backups – 3-2-1 rule implemented.
4. Patch management – critical vulnerabilities patched within 72 hours.
5. Email filtering with anti-phishing controls – SPF, DKIM, DMARC configured.
6. Network segmentation – separate Wi-Fi for guests/IoT from corporate network.

People & Process Controls

7. Annual security awareness training plus monthly phishing simulations.
8. Written Incident Response Plan – tested via tabletop exercise.
9. Data classification policy – employees know how to handle each data type.
10. Vendor security assessment – all Tier 1 vendors assessed annually.
11. Access management – least privilege enforced; access reviewed quarterly.
12. Board-level cyber risk reporting – monthly dashboard, annual deep review.

T H A N K Y O U

**Stay Secure.
Stay Vigilant.
Stay Ahead.**

Cybersecurity Basics for Business Professionals
Jain Online MCC ▶ Shrikrishna ▶ May-June 2026